SisMA — Matriz de Permissões RBAC & Rastreabilidade de Auditoria

Especificação Técnica das Regras de Acesso por Perfil e Registro Imutável de Logs com Geolocalização e IP

Este documento estabelece as diretrizes normativas e técnicas de Controle de Acesso Baseado em Papéis (RBAC - Role-Based Access Control) do SisMA (Sistema Municipal de Meio Ambiente), detalhando os privilégios operacionais dos 4 perfis do sistema, as restrições estritas de deleção de registros e a arquitetura da Trilha de Auditoria Imutável.

1. Matriz de Permissões dos 4 Perfis de Acesso (RBAC)

O SisMA estrutura o acesso operacional em quatro perfis bem definidos para garantir o cumprimento do princípio do menor privilégio e a integridade jurídica de todos os processos ambientais municipais.

Perfil de Acesso	Acessos & Funcionalidades Permitidas	Gestão de Usuários	Regra de Deleção
1. Administrador (adm)	Acesso irrestrito a todos os módulos: Gestão Geral, Licenciamento, Vistorias, Denúncias, WebGIS, Tabela de Taxas, Gestão de Servidores, Renovação da Licença do Sistema (90 dias) e Trilha de Auditoria/Logs.	Pode cadastrar, editar e gerenciar todos os 4 perfis (ADM, Analista, Fiscal e Empresário).	Possui permissão técnica para exclusão e gerenciamento avançado.
2. Analista (analista)	Gestão de Processos de Licenciamento Digital (LP, LI, LO, LAS): análise técnica, pareceres, solicitação de documentos complementares, deferimento e indeferimento.	Pode cadastrar novos Fiscais Ambientais e Empresários/Requerentes .	PROIBIDO DELETAR: Não pode excluir processos, pareceres ou documentos criados.
3. Fiscal (fiscal)	Fiscalização e Vistorias de Campo: execução de ordens de serviço, emissão de Autos de Infração, notificações e envio de relatórios com fotos e vídeos MP4 georreferenciados.	Sem permissão para cadastro ou gestão de usuários no sistema.	PROIBIDO DELETAR: Não pode excluir autos, autos de infração, fotos ou registros.
4. Empresário (empresario)	Portal do Requerente: solicitação de licenças ambientais, acompanhamento de processos próprios, envio de documentos e consulta a taxas.	Sem permissão para gestão de usuários.	PROIBIDO DELETAR: Não pode excluir solicitações ou documentos submetidos.

2. Política de Imutabilidade e Regras de Proteção de Dados

Para resguardar o município contra adulterações indevidas em processos administrativos e procedimentos fiscais, o SisMA implementa políticas estritas no nível do banco de dados (PostgreSQL / Supabase RLS):

- **Proibição Geral de Exclusão (Soft Delete / Imutabilidade):** Usuários dos perfis Analista, Fiscal e Empresário não possuem a prerrogativa de deletar registros uma vez criados no banco de dados. Qualquer alteração gera uma nova versão auditável.
- **Autenticidade de Evidências Multimídia:** As fotos e vídeos gravados durante vistorias de campo recebem marca d'água digital contendo a data, hora exata e as coordenadas geográficas capturadas pelo GPS do dispositivo.
- **Validação por Perfis (RBAC RLS):** As tabelas do Supabase ativam o mecanismo Row Level Security (RLS), garantindo que um Empresário visualize unicamente seus próprios processos, enquanto o Analista e o Fiscal acessem somente suas atribuições funcionais.

3. Rastreabilidade Total na Aba Auditoria (Auditoria.tsx)

A aba Auditoria & Logs de Segurança registra de forma contínua e imutável 100% das ações e transações executadas por qualquer um dos 4 perfis no sistema. Esse mecanismo garante a total auditabilidade do SisMA perante órgãos de controle interno, Tribunal de Contas e Ministério Público.

Campo Registrado	Descrição & Tipo de Dado	Exemplo de Registro Capturado
1. Usuário & Perfil	Nome completo, e-mail, CPF/CNPJ e badge do perfil ativo (ADM, Analista, Fiscal, Empresário).	MÁRCIO RODRIGUES DE OLIVEIRA (cda.marcio@gmail.com) [ADM]
2. Ação Realizada	Detalhamento completo da operação executada (Ex: Aprovação, Emissão de Auto, Cadastro de Usuário, Solicitação).	Emissão de Auto de Vistoria e Notificação (VIS-2026-0041)
3. Módulo do Sistema	Identificação do módulo funcional onde a ação foi disparada.	Fiscalização & Vistorias de Campo
4. Horário & Data	Timestamp com precisão de segundos (Data e Hora local).	2026-10-27 18:41:16
5. Endereço IP	Endereço IP da máquina desktop ou dispositivo móvel utilizado.	177.136.204.89 (Conexão Segura SSL)
6. Geolocalização GPS	Coordenadas geográficas exatas e identificação do município/estado de acesso.	-12.9714, -38.5014 (Cuiabá / MT - GPS de Campo)